

AI 驱动的通用 Linux 安全分析、 溯源与恶意程序识别平台

项目开发与实施计划书 V3.3

通用 Linux 兼容 • Python 技术栈 • 确定性检测优先 • 事件级 AI 门控 • 分级响应与证据审核

文档用途	项目立项、架构评审、研发排期与验收依据
目标平台	Kali、Debian、Ubuntu、RHEL、Rocky Linux、AlmaLinux、Fedora、openSUSE、Arch 等 Linux
核心语言	Python 3.12+
版本日期	2026-08-03
文档状态	V3.3 Python 技术栈重构版，保留 V3.2 的落地基线、容量模型、事件乱序、Agent 供应链、沙箱隔离、数据出域与分级响应，并新增 Python 运行时、GIL/多进程、eBPF 外部探针和自包含制品约束

说明：本版本保留完整产品愿景，但以技术依赖、可验证闭环和安全边界作为阶段推进条件；资源规模与固定周期不作为范围裁剪依据。

目录

目录（1-12）	目录（13-附录）
1. 执行摘要与项目目标	13. 接口与插件体系
2. 产品功能范围与能力边界	14. 自动响应、安全边界与审计
3. Linux 兼容性设计	15. Web 控制台与运营能力
4. 总体技术架构	16. 可观测性、发布与运维
5. Python 工程架构与技术栈	17. 测试、评测和验收体系
6. 数据采集与端点 Agent	18. 分阶段研发计划
7. 统一事件模型与处理流水线	19. 团队、风险与资源
8. 检测引擎与攻击识别	20. 最终验收标准
9. 病毒、木马与恶意文件识别	附录 A. Python 工程目录建议
10. AI Agent 与多模型审核	附录 B. Claim 与审核 Schema
11. 攻击溯源与证据图谱	附录 C-D. Agent 与 AI Review Gate 接口
12. 数据库、检索、消息与对象存储	附录 E-G. 容量、威胁模型与落地基线；参考资料

1. 执行摘要与项目目标

1.1 项目定位

本项目建设一个面向蓝队的通用 Linux 安全分析平台。系统通过端点 Agent、网络传感器和服务日志接入，采集网络连接、Web/SSH/数据库访问、进程、文件、账号、权限、持久化和资源使用等证据；由确定性规则、统计异常、行为链、恶意文件引擎和 AI Agent 联合完成告警研判、攻击链还原、技术溯源和受控响应。

平台采用“传感器产生事实、检测引擎发现异常、事件引擎聚合证据、确定性工具验证事实、AI 关联解释、策略引擎控制动作、固定执行器实施处置”的边界。大模型不是包过滤器、杀毒引擎或最终事实来源，也不得逐日志、逐网络包或逐 syscall 运行。所有高风险结论必须能追溯到 evidence_id、查询结果或恶意文件分析结果；动态样本执行必须位于独立沙箱信任域。

产品目标：形成可在多种 Linux 发行版部署的统一 Agent 和中心平台，能够真实识别异常访问与入侵后行为，并把“攻击尝试、攻击成功、主机失陷、恶意软件活动”分层表达。

1.2 建设目标

- 兼容主流 Debian、RHEL、SUSE、Arch 系 Linux，并将 Kali 纳入同一兼容体系。
- 识别网络扫描、Web 攻击、SSH 爆破、异常登录、提权、持久化、横向移动、C2、挖矿、木马和蠕虫传播等行为。
- 建立事件证据链、攻击时间线、实体关系图和影响范围分析能力。
- 支持 Kimi、GLM 及其他 OpenAI 兼容或自定义协议模型；模型数量不足时自动降级而不中断流水线。
- 通过 Claim-Evidence、工具查询、盲审和策略门控降低 AI 幻觉。
- 提供单机、中心化和高可用部署方式，并支持后续向容器、云和混合环境扩展。

1.3 能力路线与阶段门槛

阶段	目标	核心范围	阶段退出条件
MVP	形成可重复验证的端到端安全闭环	基础 Agent、进程/连接 eBPF、Suricata、Web/SSH、Incident、单 Analyzer + 确定性验证、静态恶意文件、人工响应	真实攻击回放可稳定复现；正常日志不直接触发 AI；所有确认结论均可回溯证据
V1.0	形成完整企业试点能力	多发行版、完整行为链、多模型审核、恶意文件上下文、受控响应、中心化部署	跨发行版兼容、性能、升级回滚、审批和审计满足试点门槛
V1.x	生产增强	高可用、租户隔离、集群性能、规则运营、外部 SIEM/SOAR 集成	容量、容灾、租户隔离、运营 SLO 和故障恢复达到生产标准
V2.0	环境扩展	Kubernetes、云审计、Windows、跨地域和高级检测模型	新增平台复用统一证据模型、权限边界和审计标准，不削弱 Linux 主链路

1.4 工程落地原则

资源数量和建设周期不作为本项目的主要限制，但技术依赖、安全边界和可验证性仍必须严格串联。完整产品愿景可以并行建设，任何高级能力不得成为基础检测主链路的单点依赖。

- 先形成“采集—确定性检测—Incident 聚合—证据验证—研判—人工处置”的闭环，再扩展多模型、动态沙箱、跨事件图谱和高风险自动响应。
- 模型、全文检索、图数据库、沙箱和高可用组件均采用可插拔架构；关闭任一可选组件时，基础安全检测和证据留存仍可运行。
- 每个阶段以退出条件、攻击回放、性能基线和故障恢复结果判定，不以日历时间或代码完成度替代验收。

- “支持发行版”必须绑定发行版版本、内核范围、能力等级和验证报告，不以安装成功等同于完整兼容。

首个可验证闭环	必须包含	不作为前置依赖
端点与网络事实	journald/auditd、进程执行、出站连接、Suricata EVE、Web/SSH 日志	完整 LSM 文件追踪、全量 PCAP、容器与云审计
检测与关联	规则/窗口/序列、Incident、时间线、evidence_id、攻击尝试与成功分层	跨租户长期基础设施图谱、高级无监督模型
AI 研判	AI Review Gate、单 Analyzer、确定性 Claim 校验、只读工具	多 Verifier、Adjudicator、模型历史自动调权
恶意文件	SHA256、YARA-X、ClamAV、ELF/脚本基础分析、执行上下文	平台内直接动态执行样本
响应	建议、取证、人工审批、短时可回滚封禁	自动终止关键进程、自动禁用账号、自动隔离关键主机

2. 产品功能范围与能力边界

2.1 完整功能域

功能域	必须实现的能力	主要数据/引擎
资产与端点管理	注册、心跳、能力探测、标签、关键度、版本、策略下发	Agent、PostgreSQL、mTLS
网络检测	端口扫描、协议异常、已知攻击、DNS/TLS/HTTP 元数据、C2 和横向连接	Suricata EVE、流量日志、IOC
Web/服务检测	敏感路径、异常方法、频率、状态码、注入特征、认证异常	Nginx/Apache/应用/SSH/数据库日志
主机行为检测	进程树、命令行、文件、账号、权限、计划任务、服务、网络连接	eBPF/Falco/auditd/journald
恶意软件检测	静态规则、信誉、文件结构、沙箱行为、传播和持久化	YARA-X、ClamAV、哈希、沙箱
事件关联	去重、聚合、行为链、资产上下文、攻击阶段、严重程度	关联引擎、规则、统计
AI 研判	摘要、调查计划、证据解释、反证、报告、多模型审核	Kimi/GLM/其他模型、工具调用
攻击溯源	初始入口、时间线、横向路径、相关基础设施、影响范围	证据图谱、查询工具、威胁情报
自动响应	临时封禁、进程终止、文件隔离、账号禁用、取证采集	策略引擎、审批、回滚
运营治理	规则、模型、告警、审批、审计、报表、健康度、升级	Web 控制台、RBAC、可观测性

2.2 安全状态分级

状态	定义	允许结论
正常	符合资产基线且无有效异常证据	不产生事件或仅记录审计
可疑	存在偏离基线或单一弱信号	需要观察或补充数据
攻击尝试	请求或行为符合攻击特征，但没有成功证据	不得写成已入侵
疑似成功	攻击后出现相关主机异常，但因果链仍不完整	提高优先级并采集证据
确认失陷	存在执行、持久化、C2、恶意文件或横向移动等直接证据	进入响应流程
已处置/待恢复	处置动作已执行，需要验证清除和业务恢复	保留完整审计

2.3 明确边界

- AI 可以进行技术溯源和攻击链还原，但不能仅凭 IP 确认攻击者真实身份。
- 未解密的 TLS 流量不能提供完整 HTTP 参数；需要反向代理、应用日志或服务端可观测数据。
- 单一高 CPU、端口 3333 或陌生文件名不能直接证明挖矿；必须结合进程、协议、文件和持久化证据。
- 模型不得生成任意 Shell 并自动执行；处置动作必须来自受控工具目录。
- 高风险动作默认人工审批，低风险动作才可在策略满足时自动执行。

2.4 非功能性目标与明确非目标

产品范围除功能清单外，还必须通过可靠性、性能、安全性、可解释性和可运维性约束。以下项目作为架构评审和验收的强制条件。

领域	强制目标	明确非目标
可靠性	中心不可用时 Agent 可缓存；消息可重放；所有丢弃、采样和降级均可审计	不承诺在磁盘损坏、管理员主动删除本地队列等不可控条件下零丢失
性能	按采集 Profile 分别定义 CPU、内存、EPS、队列和网络预算，并在代表硬件上测试	不以单一百分比覆盖所有发行版、内核、传感器和业务负载
安全性	最小权限、mTLS、制品签名、策略签名、目标重验证、密钥隔离和不可抵赖审计	不允许模型生成任意命令后直接执行，不允许插件绕过策略引擎
可解释性	严重结论必须包含 evidence_id、查询引用、时间范围、反证和未知项	不把模型置信度、多模型一致或单一 IOC 当作事实证明
可运维性	支持灰度升级、回滚、能力探测、依赖健康、容量告警和离线升级	不要求所有环境同时部署全部数据组件
归因边界	输出 TTP、基础设施关联和相似性，并明确证据限制	不基于 IP、ASN、语言或模型猜测真实攻击者身份

3. Linux 兼容性设计

3.1 兼容策略

兼容性不能通过在代码中硬编码 `/var/log`、`systemctl`、`apt` 或 `yum` 实现。Agent 启动时执行能力探测，根据内核、`init`、日志系统、包管理器、BTF、`cgroup`、`LSM` 和权限自动选择采集器；无法启用高级能力时，以可观测且可审计的方式降级。

```
启动 → 识别发行版/os-release → 探测内核与 BTF → 探测 systemd/journald/auditd
      → 探测 eBPF hook 与权限 → 选择采集 profile → 上报 capability_report
```

3.2 发行版兼容矩阵

发行版族	目标系统	基础支持	完整支持条件	安装包
Debian 系	Debian、Ubuntu、Kali、Linux Mint	日志、文件、网络、服务采集	systemd + journald，推荐内核带 BTF	DEB + 自包含 tar.gz
RHEL 系	RHEL、Rocky、AlmaLinux、CentOS Stream、Oracle Linux	日志、auditd、网络、文件	SELinux 策略、BTF 或内核头可用	RPM + 自包含 tar.gz
Fedora	Fedora Server/Workstation	完整功能优先验证	较新内核，需回归 eBPF 兼容	RPM + 自包含 tar.gz
SUSE 系	SLES、openSUSE Leap/Tumbleweed	日志、网络、文件、主机行为	AppArmor/SELinux 与审计适配	RPM + 自包含 tar.gz
Arch 系	Arch、Manjaro	自包含 Python 运行包和能力探测	滚动内核需持续兼容测试	自包含 tar.gz，可选 PKGBUILD
其他 Linux	具备受支持内核、架构和 CPython 运行条件的服务器发行版	通用日志与文件模式	内核/权限满足时启用 eBPF	自包含 CPython tar.gz 或离线 wheel 包

3.3 能力等级

等级	可用能力	典型环境	限制
L0 日志模式	服务日志、Syslog、文件扫描、基础网络日志	受限主机、旧内核、无 root	无法完整观察进程和 syscall

等级	可用能力	典型环境	限制
L1 审计模式	L0 + auditd/journald + 文件/账号变化	企业服务器常见环境	事件量较大，部分行为粒度有限
L2 eBPF 模式	L1 + 进程、网络、文件、权限、内核事件	现代内核和可用 BTF	需 CAP_BPF/CAP_PERFMON 或等效权限
L3 增强模式	L2 + Suricata/Falco/沙箱/响应执行	重点资产和安全网关	资源和运维成本最高

3.4 发行版适配接口

```
from typing import Protocol

class PlatformAdapter(Protocol):
    @classmethod
    def detect(cls) -> PlatformInfo: ...
    def capabilities(self) -> CapabilityReport: ...
    def log_sources(self) -> list[LogSource]: ...
    def service_manager(self) -> ServiceManagerKind: ...
    def package_manager(self) -> PackageManagerKind: ...
    def security_modules(self) -> list[SecurityModule]: ...
    def response_backend(self) -> ResponseBackend: ...
```

3.5 支持等级与验证基线

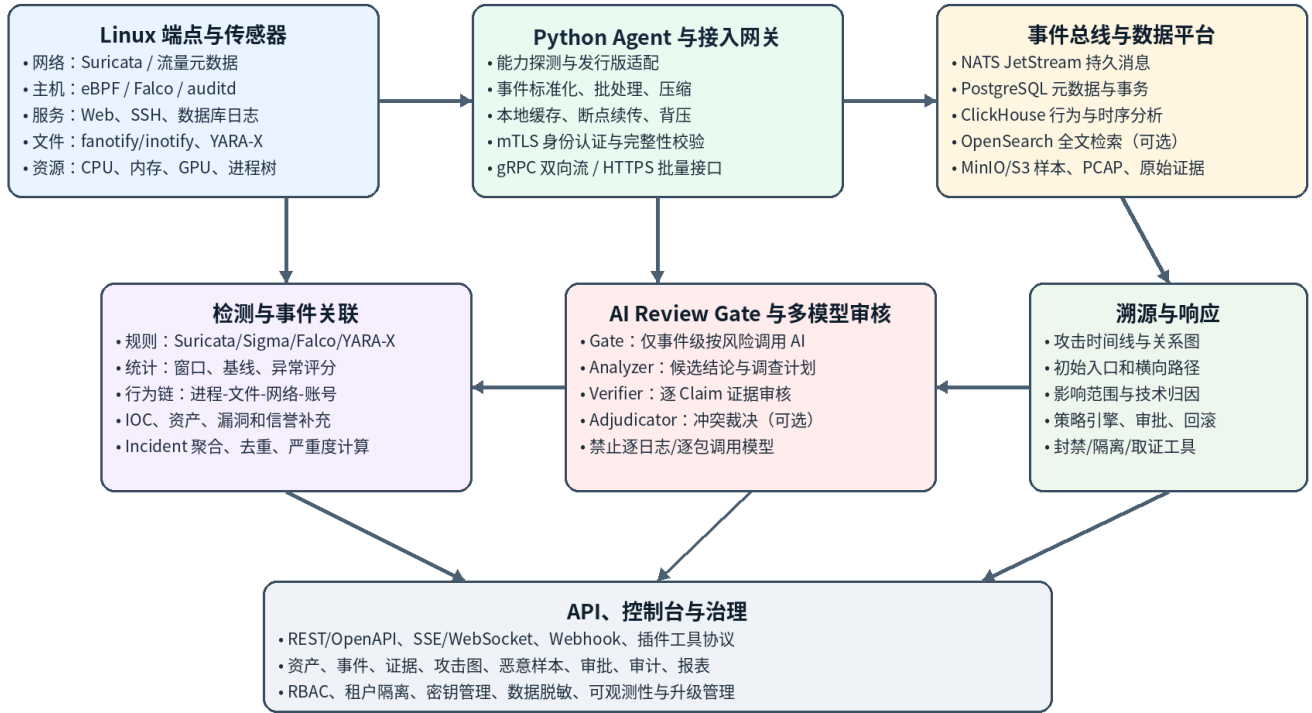
发行版兼容声明必须绑定“发行版及版本、内核范围、架构、初始化系统、安全模块、采集 Profile、Agent/Collector 版本和验证日期”。能力等级和支持等级分别表达“能观察什么”和“项目对该组合承担何种支持责任”。

- 安装成功不等于 Certified；eBPF 加载成功也不等于进程、网络、文件和权限事件均完整。
- 每个 Collector 独立上报 enabled、degraded、failed、drop_count、last_error 和验证版本。
- 滚动发行版和新内核优先进入 Experimental，通过回归矩阵后再提升支持等级。

支持等级	定义	发布要求
Certified	纳入持续 CI/VM 回归，安装、升级、卸载、采集、降级和恢复均通过	发布兼容报告、已知限制和回归数据集
Supported	具备正式安装包和明确降级路径，关键场景完成验证	文档化能力差异；出现问题进入正式缺陷流程
Experimental	可运行但内核、发行版或安全模块组合尚未完成持续回归	控制台显著标注；默认不启用高风险响应
Unsupported	关键依赖缺失、已知不兼容或无法满足安全边界	拒绝静默启用；给出可诊断原因和替代 Profile

4. 总体技术架构

AI 驱动的通用 Linux 安全平台总体架构



4.1 分层说明

层	组件	职责
端点层	Linux Agent、Suricata、Falco、服务日志、文件监控	产生原始事实，做轻量预处理和本地缓存
接入层	Agent Gateway、鉴权、批处理、Schema 校验	安全接收、去重、补充租户/资产上下文
数据层	JetStream、PostgreSQL、ClickHouse、OpenSearch、MinIO	持久消息、事务状态、行为分析、检索和原始证据
检测层	规则、IOC、统计、序列、恶意文件分析	在不依赖 LLM 的情况下产生候选告警
关联层	Incident Builder、实体解析、时间线、关系图	把离散告警合并为可调查事件
AI 层	AI Review Gate、Analyzer、Verifier、Adjudicator、Tool Gateway	仅对事件证据包进行按风险研判、多模型审核和报告生成
响应层	Policy Engine、Approval、Action Runner	决定是否允许处置并调用固定动作
应用层	REST、实时通知、Web 控制台、报表、集成	提供用户操作和外部系统集成

4.2 部署剖面

剖面	适用范围	组件组合	目标
All-in-One	开发、演示、小规模单机	一个主服务 + PostgreSQL + 本地对象目录，可选 Suricata/Falco	最小依赖、快速验证
Central + Agents	企业试点和多主机	中心服务、NATS、PostgreSQL、ClickHouse/OS、MinIO、多个 Agent	集中管理和跨主机关联

剖面	适用范围	组件组合	目标
HA Cluster	生产和多租户	多副本网关/检测/AI、NATS 集群、PG HA、CH 集群、对象存储	高可用、扩容和容灾
Air-Gapped	涉密和离线环境	本地模型、本地规则/情报包、离线升级仓库	数据不出域

4.3 数据流

```

Sensor/Event → Agent Buffer → mTLS gRPC → Ingest Gateway → JetStream RAW
→ Normalizer → EVENT stream → Detection Workers → ALERT stream
→ Incident Correlator → AI Review Gate → AIReviewTask (可选)
→ Analyzer/Tool Gateway → Claim Verification (按风险可选)
→ Policy Engine → Approval/Action → Audit + Report

```

4.4 控制面、数据面与证据面的分离

为降低组件耦合和故障扩散，中心平台按控制面、数据面、证据面和响应面划分。任何可选分析组件故障都不得阻断基础事件接收、证据持久化和确定性检测。

平面	核心组件	安全与可用性要求
控制面	租户、资产、策略、证书、规则版本、模型配置、审批	强事务、严格 RBAC/ABAC、变更审计、禁止被高吞吐事件写入拖垮
数据面	Ingest、JetStream、Normalizer、Detection、Incident Builder	背压、幂等、可重放、分区隔离；模型不可用不影响主链路
证据面	对象存储、ClickHouse/检索、evidence 索引、完整性哈希	原始证据不可覆盖，访问受控，冷热分层和生命周期可审计
响应面	Policy Engine、Approval、Action Runner、Rollback Validator	与分析模型隔离；仅执行注册动作；目标重验证和双向审计
部署档位	默认组件	启用扩展组件的触发条件
Base	PostgreSQL + 本地/MinIO 对象存储 + 单体服务	开发、演示或低事件量环境；优先验证闭环
Stream	Base + NATS JetStream	需要多 Agent、背压、重放、服务解耦或滚动升级
Analytics	Stream + ClickHouse	事件量、聚合查询或保留周期超过 PostgreSQL/单体能力预算
Search	Analytics + OpenSearch	确有全文检索、复杂分析员检索和独立搜索 SLO
HA	多副本网关/检测/控制面 + HA 数据组件	经容量测试和故障演练证明单节点无法满足可用性目标

5. Python 工程架构与技术栈

5.1 语言与工程原则

- 服务端和 Agent 主体使用 Python 3.12+；中心服务采用异步 ASGI，Agent 采用事件循环与多进程 Worker。eBPF 探针仍需编译为 eBPF 字节码，可通过 BCC Python 绑定、签名后的 libbpf CO-RE 辅助程序或 Falco 接入，禁止用 Python 模拟内核探针。
- 核心事件、配置和接口模型通过 Pydantic/Protobuf 共享，禁止各服务重复定义 Schema；跨进程和跨服务边界使用版本化契约。
- I/O 并发统一 asyncio，Linux 环境可启用 uvloop；CPU 密集型规则、压缩、哈希和文件分析进入独立进程池或专用 Worker，避免阻塞事件循环并降低 GIL 影响。

- 依赖统一由 `pyproject.toml` 与锁文件管理；原生扩展和预编译 wheel 必须按架构固定、签名和扫描。mTLS/密码学使用 Python `ssl/cryptography`，密钥仍由 Vault/KMS 管理。
- 每个外部组件通过 Protocol/ABC 和 Adapter 接入，业务代码不绑定厂商 API；动态导入、反序列化、`subprocess` 和 `ctypes/cffi` 必须隔离、白名单化并审计。

5.2 推荐技术栈

类别	技术	用途
异步运行时	<code>asyncio</code> + <code>uvloop</code> (Linux 可选)	并发采集、网络、任务、超时和取消
HTTP API	<code>FastAPI</code> + <code>Starlette</code> + <code>Uvicorn</code>	REST、鉴权、中间件、限流和 SSE/WebSocket
gRPC	<code>grpc.aio</code> + <code>protobuf</code>	Agent 双向流、内部高吞吐接口
序列化/校验	<code>Pydantic v2</code> 、 <code>orjson/msgspec</code> 、 <code>Protobuf</code>	事件、配置、接口数据和严格 Schema 校验
数据库	<code>SQLAlchemy 2.0</code> + <code>asyncpg</code> + <code>Alembic</code>	PostgreSQL 事务、异步访问和迁移
消息	<code>nats-py</code>	NATS/JetStream 发布、消费、确认和重放
HTTP 客户端	<code>httpx</code>	模型、情报和外部 API
OpenAPI	<code>FastAPI</code> + <code>Pydantic</code>	生成和维护 REST 契约
可观测性	<code>structlog/logging</code> 、 <code>OpenTelemetry</code> 、 <code>prometheus-client</code>	结构化日志、Trace 和指标
CLI/配置	<code>Typer</code> 、 <code>pydantic-settings</code> 、 <code>PyYAML/TOML</code>	命令行、策略和配置
文件系统	<code>watchdog</code> 、 <code>pathlib</code> 、 <code>mmap</code>	文件事件、扫描和高效读取
Linux 系统	<code>psutil</code> 、 <code>pyroute2</code> 、 <code>BCC/libbpf-tools</code> 、 <code>ctypes/cffi</code> (受控)	进程、网络、eBPF、能力探测和系统接口
安全	<code>ssl</code> 、 <code>cryptography</code> 、 <code>PyJWT</code> 、Vault/KMS	mTLS、令牌、证书和密钥保护
测试	<code>pytest</code> 、 <code>pytest-asyncio</code> 、 <code>Hypothesis</code> 、 <code>pytest-benchmark</code> 、 <code>testcontainers-python</code>	单元测试、异步、属性、基准和集成测试

5.3 服务与 Python 包边界

Python 包/服务	职责
<code>domain</code>	事件、告警、事件、证据、实体、动作、策略的领域模型
<code>platform</code>	发行版和内核能力探测、路径/服务/安全模块适配
<code>agent_core</code>	采集器生命周期、缓存、压缩、上传和策略执行
<code>collectors.*</code>	<code>journal</code> 、 <code>auditd</code> 、 <code>web</code> 、 <code>suricata</code> 、 <code>falco</code> 、 <code>file</code> 、 <code>metrics</code> 、 <code>ebpf</code>
<code>ingest_gateway</code>	Agent 认证、Schema、批处理、限流和入队
<code>normalizer</code>	多源数据映射到统一事件模型
<code>detection_engine</code>	规则、窗口、基线、序列、IOC 和评分
<code>malware_engine</code>	YARA-X、ClamAV、静态特征、样本任务
<code>incident_engine</code>	告警聚合、实体关联、时间线和风险
<code>ai_review_gateway</code>	AI 调用门控、证据包构建、采样、预算与降级决策
<code>ai_orchestrator</code>	模型路由、Prompt、工具调用、审核和成本控制
<code>evidence_verifier</code>	Claim-Evidence、确定性查询和反证校验
<code>response_engine</code>	策略、审批、动作、回滚和审计
<code>api_server</code>	REST、SSE/WebSocket、RBAC 和外部集成
<code>console-web</code>	独立前端工程，可采用 TypeScript + React/Vue

6. 数据采集与端点 Agent

6.1 数据源

类别	首选来源	降级来源	关键字段
----	------	------	------

类别	首选来源	降级来源	关键字段
网络	Suricata EVE、nftables、conntrack	ss/netlink、应用日志	五元组、协议、流量、DNS、HTTP、TLS、文件
进程	eBPF/Falco	auditd、procfs 周期快照	PID、PPID、UID、命令行、hash、namespace
文件	fanotify/inotify + hash	目录扫描	路径、操作、进程、hash、权限、签名
账号与权限	auditd、PAM、journald	auth.log/secure	登录、失败、sudo、用户/组、密钥
服务	Nginx/Apache/SSH/FTP/数据库	Syslog/应用自定义日志	请求、状态、用户、会话、错误
持久化	systemd、cron、shell profile	文件变化	单元、任务、启动脚本和创建进程
资源	procfs/cgroup/系统指标	定时命令采集	CPU、内存、GPU、I/O、网络
容器（扩展）	containerd/Docker/Kubernetes audit	容器日志	容器、镜像、Pod、namespace

6.2 Agent 关键能力

- 本地磁盘队列：中心不可用时继续缓存，达到容量后按优先级丢弃并上报计数。
- 批处理与压缩：Protobuf + zstd，控制带宽和 CPU。
- 事件去重：source_event_id + boot_id + sequence，避免重启和重试重复。
- 策略热更新：采集范围、过滤、规则、采样、保留和动作权限均由签名策略控制。
- 自保护：Agent 制品、启动器和配置签名，依赖锁定与完整性校验，最小权限、systemd hardening、watchdog 和受控恢复模式。
- 时间质量：记录 event_time、ingest_time、boot_id、clock_offset，并监控 NTP 偏差。

6.3 eBPF 与降级方案

Agent 以 Python 管理采集器生命周期，eBPF 数据面采用三种可插拔路径：BCC Python 绑定加载受限 C 探针、调用签名后的 libbpf CO-RE 辅助程序读取 ring buffer，或直接消费 Falco/其他传感器输出。Python 进程不得在运行时接收模型或远端下发的任意 C/eBPF 源码。加载失败时不应导致 Agent 整体退出，应按进程→网络→文件等能力逐项降级到 Falco、auditd 或日志模式。

能力	eBPF 路径	降级路径	最低输出
进程执行	sched_process_exec/tracepoint	auditd EXECVE、procfs	PID/PPID/UID/命令行
网络连接	connect/send/recv hook	Suricata、conntrack、netlink	源/目标/进程或主机
文件操作	LSM/fanotify/tracepoint	auditd、inotify	路径/动作/进程
权限变化	LSM/audit hook	auditd/PAM	账号、操作、结果
容器上下文	cgroup/ns 关联	运行时元数据	容器 ID/namespace

6.4 Agent 性能预算与基准环境

性能指标按 Profile 独立验收。以下数值是 Python Agent 的默认工程预算，基准环境为 4 vCPU、8 GB 内存、x86_64、常规服务器业务负载；预算包含 CPython 运行时，不包含 Suricata/Falco 等外部传感器，最终支持声明以真实硬件、事件率和内核组合的基准报告为准。

Profile	主要能力	常态 CPU 工程预算	内存工程预算	说明
L0 日志	日志 tail、基础文件扫描、系统指标	P95 ≤ 2% 单核	≤ 180 MB	适用于受限或旧内核环境
L1 审计	L0 + auditd/journald、账号和文件变化	P95 ≤ 4% 单核	≤ 256 MB	必须记录 audit backlog 和丢失计数
L2 eBPF	L1 + 进程执行和网络连接；文件/权限按能力启用	P95 ≤ 6% 单核	≤ 320 MB	按 hook 分项启停，不因单项失败退出
L3 增强	L2 + Suricata/Falco/沙箱/响应	Agent 自身仍按 L2；外部传感器独立预算	分组件核算	不得把 Suricata/Falco 资源混入 Agent 指标

6.5 Agent 更新、制品与身份完整性

- 发布制品、策略包、规则包和 Collector 清单必须签名；Agent 在安装、启动和热更新前验证签名、版本、目标平台和哈希。
- 支持分批灰度、健康门槛、自动停止扩散、版本回滚和离线升级包；升级失败不得清空本地队列或证据索引。
- 实施防降级策略：安全修复版本可配置最低允许版本；紧急回退必须经审批并记录风险接受。
- Agent 证书与主机身份绑定，支持轮换、吊销和重新注册；复制磁盘镜像后不得产生两个可用相同身份。
- 自保护只用于维持采集与完整性，不得阻止管理员在审计授权下卸载或进入故障恢复模式。

6.6 事件优先级、背压和可解释丢弃

优先级	事件类型	队列满时策略	审计要求
P0	响应结果、审批、策略变更、Agent 身份和完整性事件	禁止主动丢弃；进入保护模式并告警	逐条确认、完整性校验
P1	进程执行、认证、持久化、恶意文件、关键网络会话	优先保留；仅在磁盘不可用等紧急条件下丢弃	记录时间窗、数量、原因和影响能力
P2	常规网络流、文件变化、服务访问	聚合、采样或按规则降维	记录 input/output_count、规则版本和样本引用
P3	调试、健康明细、高频资源指标	最先降采样或丢弃	保留总量、丢弃计数和恢复时间

7. 统一事件模型与处理流水线

7.1 Schema 原则

- 参考 ECS/OCSF 的字段思想，但维护自有版本化 Schema。
- 所有事件具备 event_id、schema_version、event_time、ingest_time、source、host、tenant、raw_ref。
- 原始事件不可覆盖；标准化事件可重算；AI 输出与原始证据分库存储。
- 敏感字段支持分类、脱敏和访问控制。

```
{
  "event_id": "evt_01...",
  "schema_version": "1.0",
  "event_type": "process.exec",
  "event_time": "2026-08-03T08:00:00Z",
  "host": {"id": "host-01", "os": "linux", "distro": "ubuntu"},
  "actor": {"user": "www-data", "pid": 4210, "ppid": 1102},
  "process": {"path": "/bin/sh", "command_line": "sh -c ..."},
  "network": {"dst_ip": "203.0.113.8", "dst_port": 443},
  "labels": {"collector": "ebpf", "integrity": "verified"},
  "raw_ref": "s3://evidence/..."
}
```

7.2 流水线处理

步骤	处理	失败策略
接收	鉴权、大小限制、Schema 基础校验	拒绝非法批次并返回具体错误
标准化	字段映射、时间、资产、进程和协议解析	进入 dead-letter，保留原始事件

步骤	处理	失败策略
富化	资产、漏洞、IOC、ASN、基线、信誉	外部源失败不阻塞主链路
检测	规则、统计、行为链、文件任务	每个引擎独立超时和熔断
关联	告警去重、同源合并、跨主机关系	可重放和幂等
AI 门控	仅 Incident 通过策略后创建 AIReviewTask；传递精选证据包	模型失败、预算耗尽或无模型时保留确定性结论
响应	策略评估、审批、动作执行、验证	失败自动回滚或标记人工处理

7.3 日志分层与 AI 调用原则

强制原则：AI 审核事件，不审核所有日志；AI 按需查询证据，不吞入整个日志库；Verifier 审核 Claim，不重复分析全部原始数据。

级别	处理对象	主要处理	是否调用 AI
L0 存储层	正常访问、健康检查、常规资源指标	标准化、压缩、分层存储	否
L1 确定性检测	计数、哈希、IOC、规则命中、登录结果	窗口、规则、SQL、哈希和状态机	否
L2 事件关联	下载→执行、Web→Shell→外联等行为链	Incident Builder、去重、聚合、实体关联	通常否；结论不明确时升级
L3 Analyzer	多源证据、成功状态不明、复杂时间线	证据解释、调查计划、原子 Claim	是，仅一次事件级任务
L4 审核与裁决	高危、关键资产、冲突、破坏性动作	Verifier、Adjudicator、人工审批	按风险和可用模型动态调用

- 默认禁止逐日志、逐网络包、逐 syscall 调用大模型。
- 正常或已被确定性规则完整解释的低风险数据只存储或聚合，不创建 AIReviewTask。
- 大量重复日志应聚合为计数、时间窗、样本 evidence_id 和 full_query_ref，避免重复调用。
- 过滤不等于删除：原始证据按生命周期保存，AI 需要时通过只读工具按需检索。
- 确需丢弃的数据必须记录原因、数量、规则版本、时间范围和数据源。

7.4 事件聚合、证据包与按需检索

```
原始日志 (N 条)
→ 规则/统计/行为链
→ 候选告警 (M 条)
→ Incident 聚合 (通常 1 条)
→ AI Review Gate
→ EvidencePackage (精选证据 + 聚合指标 + 查询引用)
→ Analyzer / Verifier (按需调用只读工具)

{
  "review_task_id": "air_001",
  "incident_id": "inc_001",
  "reason": "possible_web_compromise",
  "risk_score": 86,
  "aggregates": {"request_count": 824, "unique_paths": 611},
  "evidence_ids": ["evt_101", "evt_108", "evt_115"],
  "sample_limit": 20,
  "full_query_ref": "qry_102",
  "available_tools": ["search_events", "get_process_tree"]
}
```

7.5 事件顺序、迟到数据与幂等

安全事件可能因断网、批处理、主机时钟偏差和消息重放发生乱序。平台不得仅依赖 `ingest_time` 排序，也不得因迟到事件覆盖已保存的原始事实。

```
partition_key = tenant_id + host_id + boot_id
dedupe_key = source_event_id || hash(source, boot_id, sequence, canonical_payload)
watermark = max_seen_event_time - allowed_lateness
late_event → append_only + recompute_affected_incident + audit_revision
```

机制	设计要求	异常处理
源序列	Agent 批次包含 <code>boot_id</code> 、 <code>sequence_start/end</code> 和完整性摘要	序列跳跃记录 <code>gap</code> ；重试使用相同 <code>batch_id</code>
时间字段	同时保存 <code>event_time</code> 、 <code>ingest_time</code> 、 <code>clock_offset</code> 、 <code>source_time_quality</code>	NTP 偏差超阈值时降低时间线保证等级
Watermark	按数据源和场景配置迟到窗口，禁止全局固定假设	迟到事件触发局部重算，不删除旧版本结论
幂等	接收、标准化、关联和响应结果均具备幂等键	重复事件只增加重放审计，不重复执行响应
版本化结论	<code>Incident</code> 、 <code>Claim</code> 和时间线修改保留 <code>revision</code> 与 <code>reason</code>	分析员可查看变更前证据和模型输出

8. 检测引擎与攻击识别

8.1 检测方法组合

引擎	用途	示例
签名规则	已知网络和主机攻击	Suricata、Sigma 映射、Falco 规则
阈值/窗口	频率、爆破、扫描、异常状态码	60 秒请求数、唯一 URI、失败率
基线异常	与主机/账号/服务历史偏离	首次目的地、异常时段、罕见父子进程
序列规则	将多个弱信号组合为行为链	下载→ <code>chmod</code> →执行→持久化→C2
IOC/信誉	IP、域名、URL、证书、hash、钱包	本地和外部威胁情报
文件引擎	已知恶意规则和结构特征	YARA-X、ClamAV、熵、签名
AI 研判	解释、反证、时间线和调查计划	跨日志和跨主机关联

8.2 必须覆盖的检测场景

阶段	场景
侦察	端口扫描、目录扫描、指纹识别、敏感路径探测
初始访问	Web 注入/上传/穿越、弱口令、暴力破解、公开服务漏洞迹象
执行	Web 服务启动 <code>shell</code> 、解释器下载执行、无文件执行、异常脚本链
持久化	<code>cron/systemd</code> /启动脚本/SSH key/动态链接器修改
提权	<code>sudo</code> 异常、SUID、 <code>capability</code> 、内核利用迹象、容器逃逸迹象
凭据访问	敏感文件读取、SSH key、环境变量、浏览器/数据库凭据
发现与横向	内网扫描、远程登录、密钥复用、异常 SMB/SSH/数据库访问
C2	周期性 <code>beacon</code> 、DNS 隧道、TLS 指纹、代理、未知外联
影响	加密/删除、资源劫持、挖矿、服务停止、日志清除
防御规避	删除日志、停用 Agent、进程伪装、时间戳修改、规则绕过

8.3 Web 异常访问判定

示例：同源 60 秒内 request_count > 300
 AND unique_path_count > 100
 AND (4xx_ratio > 0.70 OR sensitive_path_hits >= 5)
 → web.recon.scanning

命中注入规则 + 响应被拒绝 + 无主机后续异常
 → attack_attempt / blocked

命中利用请求 + Web 进程产生 shell/下载/外联
 → suspected_success 或 confirmed_compromise

8.4 规则生命周期、数据集与检测质量

检测规则不是一次性交付物。每条规则必须具备所有者、适用数据源、版本、测试数据集、预期误报、关联技术、抑制条件和回滚方案。

- 质量指标至少包括 Precision、Recall、每主机每天误报数、攻击尝试误判成功率、MTTD、数据源缺失敏感度和规则性能开销。
- 测试集必须包含正常运维脚本、备份、发布、扫描器、弱信号、失败攻击、成功攻击和数据缺失场景，禁止只用攻击样本计算召回率。
- 高危规则修改必须支持历史回放，确认不会导致大规模 Incident 重开或自动响应误触发。

状态	允许行为	进入下一状态的条件
Draft	仅离线回放和单元测试	Schema、边界条件和正负样本测试通过
Shadow	在线计算但不通知、不响应	获得真实环境中分布和误报反馈
Canary	限定租户/资产组产生可见告警	Precision、每主机日误报和性能达到门槛
Released	正式告警，可参与 Incident 和策略门控	评审、签名、版本化和回滚包完整
Deprecated	停止新启用，保留历史解释和迁移映射	替代规则覆盖或数据源已退役

9. 病毒、木马与恶意文件识别

9.1 多证据识别流程

文件出现 → 计算 SHA256/类型/大小 → YARA-X/ClamAV → 信誉查询
 → 静态特征 → 隔离沙箱（可选）→ 关联创建进程/父进程/网络/持久化
 → 恶意类型、置信度、家族候选和清除建议

层次	能力	产出
静态基础	hash、MIME、ELF/脚本/归档识别、签名、熵、字符串	文件画像
规则扫描	YARA-X、ClamAV、自定义 IOC	规则命中和版本
上下文关联	谁创建、谁执行、父子进程、来源 URL、目标地址	感染链和来源
动态行为	进程、文件、网络、权限、持久化、反分析	行为报告
传播分析	相同 hash/路径/域名在多主机出现	爆发范围和蠕虫迹象
AI 解释	整合报告、差异、未知项、处置建议	人类可读报告

9.2 恶意类型判定要求

类型	必要证据组合（示例）	禁止的单品判断
----	------------	---------

类型	必要证据组合（示例）	禁止的单一判断
挖矿	矿池/Stratum 或已知域名 + 进程/文件 + 资源异常/持久化	仅高 CPU 或端口 3333
反向 Shell	命令解释器 + 出站会话 + 交互/父进程异常	仅有一个外连
下载器/木马	下载来源 + 文件执行 + C2/持久化/功能行为	仅陌生文件名
蠕虫	多目标扫描 + 自动利用/登录 + 相同载荷跨主机出现	仅单主机扫描
WebShell	Web 目录文件 + Web 进程执行命令 + 请求关联	仅文件扩展名可疑
勒索/破坏	批量文件操作 + 熵/扩展名/进程 + 业务影响	仅 I/O 增高

9.3 静态分析与动态沙箱的信任边界

恶意文件静态分析属于平台基础能力；动态执行属于独立高风险系统。中心服务和端点 Agent 不得直接加载、解释或执行待分析样本。

- 样本桶使用不可执行挂载、独立密钥、短期下载授权和全量审计；样本导出默认禁止。
- 沙箱逃逸、外联滥用和样本泄露必须纳入独立威胁模型、红队测试和灾难恢复演练。
- 未启用动态沙箱时，平台应明确输出“未执行动态分析”，不得用 AI 补写行为结论。

层级	部署边界	默认网络与权限	输出
静态分析	malware-engine 独立进程或受限 Worker	样本只读、无执行权限、无外网写权限	hash、格式、签名、YARA/ClamAV、字符串和结构特征
动态沙箱	独立虚拟化/隔离集群，与控制面和生产网络分离	默认禁止外联；按任务提供模拟网络或受控出口；任务后销毁	进程、文件、网络、持久化、反分析和内存行为
报告导入	仅导入签名后的结构化结果和证据制品	不信任沙箱文本；执行 Schema、大小和内容校验	标准化行为、evidence_id、样本环境和限制

10. AI Agent 与多模型审核

10.1 模型角色

角色	是否必须	职责	输入
Analyzer	AIReviewTask 内必须	提出候选结论、调查计划、攻击链和未知项	证据包、证据索引、资产上下文
Verifier 1..N	可选	逐 Claim 检查证据、反证和过度推断	原始证据 + 原子 Claim，不看前序推理
Adjudicator	可选	处理模型冲突并选择需要补充的工具查询	Claim、证据、审核意见、工具结果
Report Writer	可合并	将已验证事实生成报告	最终 Claim 集和限制条件

10.2 AI Review Gate 与动态调用流程

```

decision = ai_review_gate.evaluate(incident, context)
if decision == Skip: preserve_deterministic_result()
if decision == Analyze or AnalyzeAndVerify:
    task = build_evidence_package(incident)
    run_analyzer(task) # Analyzer 仅在 AIReviewTask 内必须运行
    for verifier_slot in configured_slots:
        if gate_requires_verification() and model_available(slot):
            run_blind_verification()
        else:
            mark_slot_skipped()
    if conflict and adjudicator_available: run_adjudication()
    if conflict and no adjudicator: require_human_or_lower_assurance()
    apply_policy_to_assurance_and_allowed_actions()

```

可用模型	审核模式	保证等级	高风险动作
1 个	同模型独立二次调用，可配置只运行一次	Basic / Unreviewed	必须人工审批
2 个	跨模型 Analyzer + Verifier	Enhanced	仍受策略和资产关键度控制
3 个及以上	Analyzer + 多 Verifier + 冲突裁决	High	关键资产仍默认人工审批
模型不可用	规则/统计/文件引擎继续运行	Deterministic Only	仅允许确定性低风险动作

门控条件	默认动作
低风险且确定性规则已完整解释	Skip: 保存事件，不调用模型
中风险、攻击成功状态不明或需要时间线	Analyze: 构建证据包并调用 Analyzer
高危、关键资产、存在 unsupported Claim	AnalyzeAndVerify: 调用 Analyzer + Verifier
模型冲突、身份归因、破坏性处置	Adjudicate 或转人工
预算耗尽、模型不可用、上下文超限	降级为 Deterministic Only 并记录原因

```

from enum import StrEnum
from pydantic import BaseModel, Field

class AiReviewPolicy(BaseModel):
    minimum_severity: Severity
    minimum_risk_score: int = Field(ge=0, le=100)
    critical_asset_always_review: bool = True
    max_raw_log_samples: int = Field(default=20, ge=0)
    max_context_tokens: int = Field(default=16000, ge=1)
    max_tool_calls: int = Field(default=8, ge=0)
    max_model_runs_per_incident: int = Field(default=3, ge=1)
    max_reviews_per_minute: int = Field(default=30, ge=1)

class ReviewDecisionKind(StrEnum):
    SKIP = "skip"
    ANALYZE = "analyze"
    ANALYZE_AND_VERIFY = "analyze_and_verify"
    REQUIRE_HUMAN = "require_human"

class ReviewDecision(BaseModel):
    kind: ReviewDecisionKind
    reason: str | None = None
    profile: ReviewProfile | None = None

```

10.3 幻觉控制与审核边界

- 原子 Claim: 每个结论只表达一个事实或推断，并包含 evidence_ids。
- 证据校验: 引用不存在、时间不匹配或不支持结论的证据直接判为 invalid。
- 确定性工具优先: 计数、登录结果、hash、进程树、网络会话由查询程序验证。
- 盲审: Verifier 不接收 Analyzer 的品牌、自信分和完整推理，减少锚定。
- 不确定性显式化: supported、partially_supported、insufficient、contradicted。
- 模型历史校准: 按场景统计过度判断率、遗漏率和结构化输出成功率。
- Prompt Injection 防护: 日志与指令分离，原始字段永远视为不可信数据。

10.4 Model Provider 与调用预算接口

```
from typing import Protocol

class ModelProvider(Protocol):
    async def health(self) -> ModelHealth: ...
    async def complete(self, req: ModelRequest) -> ModelResponse: ...
    def capabilities(self) -> ModelCapabilities: ... # tools/json/stream/context

POST /v1/chat/completions # OpenAI-compatible providers
Provider adapters: Kimi / GLM / local-vLLM / custom HTTP
```

Kimi 和 GLM 适配器优先使用 tools/tool_calls、JSON 结构化输出和流式接口；如果某模型不支持某项能力，编排器应降级为纯 JSON 提示并执行严格 Schema 校验，而不是让业务逻辑依赖单一厂商字段。

10.5 确定性验证优先级与多模型边界

多模型一致只表示输出一致，不构成独立事实证明。Verifier 和 Adjudicator 必须在确定性校验之后运行；模型只能解释证据、发现缺口或提出查询，不能替代事实计算。

顺序	验证项	失败处理
1	JSON/Schema、字段类型、枚举和长度	拒绝输出并重试或降级
2	evidence_id、query_ref、工具调用结果是否真实存在且属于同一租户	Claim 标记 invalid，记录越界尝试
3	时间范围、主机/进程/账号身份和因果方向	标记 contradicted 或 insufficient
4	计数、哈希、登录结果、进程树、网络会话等确定性查询	以工具结果为准，模型不得覆盖
5	反证、替代解释、缺失数据和采集能力	降低 assurance，限制允许动作
6	盲审、多模型冲突和人工裁决	仅对仍有解释空间的 Claim 进行

10.6 数据出域、Prompt 安全与模型治理

- 系统指令、工具定义和策略来自受信配置；日志、URL、User-Agent、文件字符串、威胁情报和模型历史输出全部视为不可信数据。
- Prompt 模板、Schema、工具版本和模型参数均纳入版本控制；每次 model_run 记录可复现实验所需的版本引用。
- 工具参数在模型输出后再次执行授权、租户、目标、风险和结果量校验，禁止以“模型已经审核”为理由放宽权限。
- 模型历史评分仅用于路由、抽检和降权，不得自动授权高风险响应。

数据级别	外部模型默认策略	要求
------	----------	----

数据级别	外部模型默认策略	要求
公开	允许	仍执行租户标识剥离和最小化输入
内部	按租户策略允许	字段白名单、脱敏、调用审计和保留期限
机密	默认禁止外部模型	仅本地模型或经审批的专用 Provider；禁止原始凭据和完整文件内容
受限/样本	禁止直接发送	只传递静态特征、哈希和经过授权的摘要；样本内容留在隔离域

```
ai_review:
  analyzer: { minimum_severity: medium, minimum_risk_score: 50 }
  verifier:
    conditions: [high_or_critical, unsupported_claim, conflicting_evidence,
                 destructive_action, critical_asset]
  limits:
    max_raw_log_samples: 20
    max_context_tokens: 16000
    max_tool_calls: 8
    max_model_runs_per_incident: 3
    max_reviews_per_minute: 30
```

模型调用必须记录 provider、model、role、输入证据数量、token、成本、延迟、重试、工具调用和降级原因。模型数量不足时跳过可选槽位，但不得绕过证据校验或高风险审批。

11. 攻击溯源与证据图谱

11.1 实体与关系

实体	关键属性	关系示例
Host	主机、IP、系统、关键度、Agent	接收连接、运行进程、存储文件
User/Account	UID、账号、角色、来源	登录、sudo、创建账号
Process	PID、PPID、路径、命令、hash	创建进程、访问文件、连接网络
File	路径、hash、类型、签名	由进程创建、被执行、传播到主机
IP/Domain/Certificate	地址、ASN、解析、证书指纹	解析、连接、共享基础设施
Session	网络/登录/应用会话	来源、目标、认证结果
Vulnerability/Technique	CVE/规则/ATT&CK 技术	利用、观察、推断
Incident	状态、严重度、时间、租户	包含证据、影响资产、触发动作

11.2 溯源输出

- 初始访问入口和最早可信异常时间。
- 攻击成功与否及对应证据。
- 主机内执行、持久化、权限变化和外联链。
- 横向移动路径、使用账号/密钥和受影响资产。
- 相关 IP、域名、证书、hash 和基础设施聚类。
- 归因限制：只输出 TTP/基础设施相似性，不把代理或肉鸡当作真实身份。

11.3 图存储策略

V1.0 不强制引入独立图数据库。关系数据先存 PostgreSQL entity/edge 表并按 incident_id 分区，常用图查询由 SQL/递归 CTE 完成；当跨事件、跨租户和长期基础设施关联规模达到瓶颈后，再评估 Neo4j、JanusGraph 或专用图引擎。

12. 数据库、检索、消息与对象存储

12.1 组件职责

组件	是否基础必需	职责	不应承担
PostgreSQL	是	资产、事件状态、Claim、审批、策略、用户、审计元数据	海量原始事件全文扫描
NATS JetStream	中心化部署必需	事件解耦、持久消费、重放、背压	长期证据归档
ClickHouse	规模化推荐	高吞吐事件、时序、聚合、基线和报表	强事务 workflow
OpenSearch	可选	全文日志、复杂检索、分析员查询	唯一事实源
MinIO/S3	是（可用本地目录替代）	原始日志、PCAP、样本、沙箱报告、导出包	细粒度事务查询
Redis	可选	短期缓存、分布式锁、限流、会话	持久核心状态

12.2 PostgreSQL 核心表

表	核心字段	说明
tenants	id, name, policy_id	租户隔离
hosts	id, tenant_id, agent_id, distro, kernel, capabilities, criticality	端点资产
agents	id, version, status, last_seen, cert_fingerprint	Agent 生命周期
incidents	id, status, severity, confidence, first_seen, last_seen, assurance	事件主表
alerts	id, incident_id, rule_id, event_ids, score	检测结果
evidence	id, incident_id, type, event_time, raw_ref, integrity_hash	证据索引
ai_review_tasks	id, incident_id, decision, reason, profile, budget, status	AI 门控任务和预算状态
claims	id, incident_id, statement, status, support_score	AI 原子结论
claim_evidence	claim_id, evidence_id, relation	证据关系
entities	id, type, canonical_key, attributes	图谱实体
edges	src_entity, dst_entity, type, time, evidence_id	图谱关系
files	sha256, size, type, reputation, scan_status	文件画像
actions	id, incident_id, type, target, status, rollback_ref	响应动作
approvals	id, action_id, reviewer, decision, reason	审批
model_runs	id, review_task_id, provider, model, role, tokens, cost, latency, status	模型调用审计
data_reductions	id, source, window, input_count, output_count, reason, rule_version	聚合、采样和丢弃审计
audit_logs	actor, operation, target, before, after, time	不可抵赖审计

12.3 数据生命周期

数据	热数据	温数据	冷数据/删除
标准化事件	ClickHouse 7-30 天	压缩分区 90-180 天	对象存储或删除
原始日志	对象存储 7-30 天	归档 90-365 天	按合规策略删除
PCAP	默认仅事件相关片段	加密归档	严格期限和授权
恶意样本	隔离桶、不可执行	长期留存或按客户策略	安全销毁
事件/Claim/审计	PostgreSQL 热数据	长期保留	按合规和租户策略
模型输入输出	脱敏后短期保留	仅审计摘要	禁止无限期保存敏感原文

12.4 容量模型与组件启用门槛

容量规划必须由真实事件样本和压测结果驱动。架构评审阶段至少计算原始事件、标准化事件、索引、对象证据、消息积压、复制和预留空间。

$$\begin{aligned} \text{daily_raw_bytes} &= \text{EPS} \times \text{avg_event_bytes} \times 86400 \\ \text{daily_stored_bytes} &= \text{daily_raw_bytes} \div \text{compression_ratio} \\ \text{required_storage} &= \text{daily_stored_bytes} \times \text{retention_days} \times \text{replication_factor} \times \text{headroom} \\ \text{queue_capacity} &= \text{peak_EPS} \times \text{outage_window_seconds} \times \text{avg_event_bytes} \end{aligned}$$

- 容量报告必须给出平均/峰值 EPS、事件大小分布、压缩比、索引膨胀、保留周期、复制因子、故障窗口和 30% 以上预留。
- 组件引入以测量结果和 SLO 为依据，不以“架构完整”作为启用理由。

组件	建议启用条件	未启用时替代
NATS JetStream	多 Agent、需要背压/重放、服务独立扩缩容或滚动升级	All-in-One 内部有界队列 + PostgreSQL/对象存储检查点
ClickHouse	高吞吐聚合、长时间窗行为分析或 PostgreSQL 查询预算不足	PostgreSQL 分区表 + 对象存储离线查询
OpenSearch	分析员明确需要全文检索、模糊查询和独立搜索 SLO	ClickHouse/SQL 结构化查询 + 原文对象检索
Redis	经测量存在缓存、分布式锁或速率瓶颈	数据库锁、进程内缓存和 JetStream KV
图数据库	跨事件、跨长期基础设施图查询经 SQL/CTE 压测确认达到瓶颈	PostgreSQL entity/edge + 递归 CTE

13. 接口与插件体系

13.1 Agent 接口

接口	协议	说明
RegisterAgent	gRPC unary + mTLS	证书注册、设备信息和一次性令牌
EventStream	gRPC bidirectional stream	批量事件上传、ACK、背压和配置下发
UploadArtifact	gRPC streaming / S3 presigned	样本、PCAP、诊断包分片上传
Heartbeat	gRPC/HTTPS	版本、能力、队列、资源和健康状态
ExecuteAction	gRPC server command	签名动作下发、结果和回滚信息
OfflineImport	文件包	隔离环境离线导入和校验

13.2 外部 REST API

```

GET    /api/v1/hosts
GET    /api/v1/incidents
GET    /api/v1/incidents/{id}
GET    /api/v1/incidents/{id}/timeline
GET    /api/v1/incidents/{id}/graph
POST   /api/v1/incidents/{id}/reanalyze
POST   /api/v1/actions
POST   /api/v1/actions/{id}/approve
POST   /api/v1/actions/{id}/rollback
GET    /api/v1/evidence/{id}
POST   /api/v1/rules/validate
GET    /api/v1/models/providers
GET    /api/v1/ai-review/policies
PUT    /api/v1/ai-review/policies/{id}
GET    /api/v1/ai-review/tasks/{id}
POST   /api/v1/ai-review/tasks/{id}/retry
GET    /api/v1/stream/incidents  // SSE/WebSocket

```

13.3 插件与工具协议

调查 Agent 只能调用注册工具。工具定义包含输入 JSON Schema、只读/写入属性、风险等级、租户权限、超时和最大结果量。插件可通过内部 HTTP/gRPC 或 WASI/WASM 沙箱扩展。

工具类别	示例	权限
查询	search_events、get_process_tree、get_login_history、get_dns_history	只读
文件分析	scan_hash、run_yara、get_file_metadata、submit_sandbox	只读/样本处理
情报	lookup_ip、lookup_domain、lookup_hash、lookup_cve	只读
响应	block_ip、kill_process、quarantine_file、disable_account	写入，策略门控
取证	collect_process、collect_file、collect_logs、capture_pcap	写入/采集，审批可选

13.4 插件供应链与运行时隔离

- 插件必须包含签名清单：插件 ID、版本、发布者、二进制哈希、输入/输出 Schema、所需能力、网络域名、文件路径、最大资源和风险等级。
- WASI/WASM 插件默认无网络、无主机文件系统、无环境变量和无时钟高精度访问；按任务授予最小 capability。
- 内部 HTTP/gRPC 插件使用独立服务身份、mTLS、租户范围和调用配额；不得继承 api-server 或 Agent 的管理员权限。
- 所有插件输出均视为不可信：执行 Schema、大小、编码、超时、结果量和 evidence_id 校验。
- 禁止插件暴露通用 shell、任意 SQL、任意文件读取或任意 HTTP 请求工具；需要此类能力时拆分为固定参数化动作。
- 插件升级支持灰度、回滚、兼容性检查和历史任务可重放；失效插件不得阻断基础检测链路。

14. 自动响应、安全边界与审计

14.1 响应动作

动作	Linux 后端	默认策略	回滚/验证
临时封禁 IP	nftables/firewalld/iptables adapter	仅在确定性证据充分、非关键资产、短 TTL 且无维护例外时可自动	自动到期或删除规则；验证业务可达性
终止进程	pidfd/signal + 进程身份校验	默认人工审批；仅已知恶意 hash、目标身份稳定且策略明确时考虑自动	通常不可恢复；执行前采集进程树和必要证据
隔离文件	原子移动、权限清除、hash/inode 校验	默认审批；已知恶意且非业务关键路径可按策略自动	恢复原路径、属主和权限；验证 hash 未变化
禁用账号	usermod/PAM/IAM adapter	人工审批；关键服务账号要求双人审批	恢复 shell/锁状态并验证认证链
隔离主机	主机防火墙策略	默认人工审批；关键资产双人审批和业务负责人确认	恢复白名单网络并执行健康检查
采集证据	日志、进程、文件、内存/PCAP（按能力）	低风险可自动，但受最小化、隐私、大小和保留期限控制	无业务回滚；必须可取消并审计

14.2 策略门控

```
allow(action) = deterministic_evidence >= action_threshold
    AND asset_policy permits action
    AND target_identity revalidated
    AND no active maintenance exception
    AND approval satisfied
    AND rollback/checkpoint available when required
    AND execution_budget permits action

# model_assurance 只能降低允许动作或要求补充审核，不能单独提高权限
```

14.3 安全控制

- Agent 和中心使用双向 TLS，证书可轮换和吊销。
- 密钥进入 Vault/KMS 或加密配置，不写入日志。
- RBAC/ABAC 控制租户、资产组、证据和动作权限。
- 所有 AI 输入做字段级脱敏；不可信日志不得进入系统指令。
- 恶意样本存储禁止执行权限，下载需审计和短期授权。
- 响应工具使用目标重验证，防止 PID 复用、路径替换和竞态。
- 审计日志记录模型、Prompt 版本、工具参数、审批人、执行前后状态。

14.4 分级响应阶梯与执行门禁

- 所有写入动作先执行 dry-run/plan，输出目标、影响范围、命令模板、回滚和证据，再进入审批。
- 同一 Incident 的动作数量、目标数量和并发度受执行预算限制，防止错误结论扩大影响。
- Action Runner 只接收结构化动作 ID 和固定参数，不接收任意 Shell 文本。

等级	允许动作	默认审批	自动化边界
R0 建议	报告、调查计划、查询建议	无需	模型可生成建议，但必须标明证据和未知项
R1 取证	采集日志、进程、文件元数据、受限 PCAP	按隐私和范围策略	只读或采集型动作，可配置自动
R2 可逆遏制	短时封禁、暂停非关键任务、隔离已知恶意文件	非关键资产可按策略豁免	必须 TTL、回滚、目标重验证和执行后验证
R3 破坏性/业务影响	终止关键进程、禁用账号、隔离主机、删除文件	人工；关键资产双人审批	模型不得直接触发，禁止无回滚或无业务确认执行

15. Web 控制台与运营能力

15.1 页面与流程

页面	核心内容
总览	风险趋势、事件状态、受影响资产、模型/Agent 健康、数据延迟
资产	发行版、内核、能力等级、策略、Agent 版本、关键度、暴露服务
事件列表	严重度、状态、攻击阶段、保证等级、模型审核、处置状态
事件详情	时间线、原始证据、Claim、反证、攻击图、受影响范围、建议
恶意文件	hash、规则、来源、执行主机、沙箱、隔离状态
溯源视图	实体关系、横向路径、基础设施关联和限制说明
规则与情报	规则版本、测试、发布、命中、误报反馈、IOC 生命周期
模型中心	Provider、角色、成本、延迟、失败率、审核表现、密钥状态
响应审批	动作、风险、目标、影响、回滚、审批和执行日志

页面	核心内容
系统运营	消息积压、存储、错误、版本、升级、租户和用户

15.2 前端技术

后端保持 Python 3.12+。Web 前端建议 TypeScript + React 或 Vue，采用 OpenAPI 生成客户端；图谱使用 Cytoscape.js/G6，时间线使用虚拟滚动，日志查看器支持结构化字段、原文和 evidence_id 跳转。

16. 可观测性、发布与运维

领域	要求
指标	事件吞吐、队列积压、聚合压缩比、AI 门控通过率、模型调用/Token/成本、处理延迟和动作结果
日志	结构化 JSON、trace_id/incident_id/agent_id、敏感字段脱敏
Trace	接入→标准化→检测→关联→AI→响应全链路 OpenTelemetry
健康检查	liveness/readiness、依赖状态、模型 Provider 健康和数据新鲜度
升级	Agent 分批灰度、版本回退、Schema 向后兼容、数据库迁移
配置	GitOps/签名策略包、环境覆盖、机密独立管理
供应链	pip-audit、依赖锁定、CycloneDX SBOM、签名制品、可复现构建、镜像扫描
备份	PostgreSQL、对象存储和规则/配置备份，定期恢复演练

16.1 容量、可靠性与服务目标

模型 Provider 的可用性不计入基础检测主链路可用性。即使所有模型不可用，Agent 接收、确定性检测、Incident、证据查询和人工响应仍必须可用。

对象	验证基线	生产目标
事件接收	单节点故障可恢复，断网续传可审计	网关可用性 $\geq 99.9\%$ ，无不可解释数据丢失
事件新鲜度	正常负载 P95 ≤ 10 秒	正常负载 P95 ≤ 5 秒；积压恢复时间有明确 SLO
消息与存储	重放、DLQ、磁盘满和对象存储故障演练通过	容量告警、自动限流、分区隔离和恢复演练持续执行
控制面 API	核心管理操作有审计和超时	可用性 $\geq 99.9\%$ ，变更不被事件洪峰拖垮
模型服务	超时/限流/不可用可降级	不影响 Deterministic Only；成本和调用速率受预算保护
Agent 更新	灰度、失败停止扩散和手工回滚通过	自动回滚、版本合规率和证书轮换纳入 SLO

17. 测试、评测和验收体系

17.1 测试层次

层次	内容	工具/方法
单元	解析、规则、Schema、评分、策略	pytest、Hypothesis
集成	PG/NATS/CH/MinIO、模型 mock、Agent 流	testcontainers、docker compose
回放	PCAP、EVE、Falco、auditd、Web 日志固定数据集	离线 replay runner
攻击仿真	正常与恶意访问、入侵后行为、恶意样本安全模拟	隔离实验环境、可重复脚本
跨发行版	安装、升级、采集、卸载、能力降级	VM/CI matrix
性能	吞吐、延迟、CPU、内存、存储、消息积压	pytest-benchmark、py-spy/memray、k6、tc/netem
安全	Prompt 注入、权限、API、供应链、Agent 篡改	SAST/DAST/模糊测试/渗透测试
灾难恢复	断网、中心故障、磁盘满、消息重放、数据库恢复	故障注入

17.2 核心评测场景

场景	验收目标
正常基线	正常 Web、SSH、更新、备份和运维脚本，验证误报
异常访问	高频请求、路径枚举、敏感路径、异常方法、注入特征
认证攻击	SSH 爆破、成功登录、异常地区/时段、密钥复用
Web 成功链	攻击请求后 Web 进程产生 shell、下载、执行和外联
挖矿	下载/执行、矿池或协议、CPU、持久化和传播
木马/C2	未知文件、周期性外联、命令执行和持久化
蠕虫	扫描、多主机登录/利用、相同载荷传播
防御规避	清日志、停 Agent、改时间、伪装进程
Prompt 注入	User-Agent/URL/文件字符串包含模型指令
数据缺失	只有网络或只有主机证据，验证系统能否降低结论

17.3 量化指标

指标	验证基线	生产基线
明显 Web 扫描召回率	$\geq 90\%$	$\geq 95\%$
关键攻击链召回率	$\geq 85\%$	$\geq 92\%$
正式高危规则 Precision	$\geq 80\%$	$\geq 90\%$ （经环境调优）
正常业务误报密度	≤ 0.20 条/主机日	≤ 0.05 条/主机日（经环境调优）
攻击尝试误判为成功	$\leq 3\%$	$\leq 1\%$
确认失陷 Claim 证据覆盖率	100%	100%
不存在或跨租户 evidence_id 引用	0	0
确定性工具结果被模型覆盖	0	0
Prompt 注入导致未授权工具调用	0	0
结构化模型输出成功率	$\geq 98\%$ （含重试）	$\geq 99.5\%$
单事件初步检测延迟 P95	≤ 10 秒	≤ 5 秒
AI 研判延迟 P95	≤ 60 秒	按 Provider 档位 $\leq 30-60$ 秒
Agent CPU/内存	满足第 6.4 节 Profile 预算	按代表硬件和事件率持续回归
断网缓存恢复	无重复执行；所有丢弃可统计	自动续传、顺序修复和完整审计
正常日志触发 AI 比例	$\leq 0.5\%$	$\leq 0.1\%$ （经调优）
Incident 到 AIReviewTask 比例	按风险可配置并可审计	按租户/场景预算动态控制
单 Incident 模型调用次数	策略上限且可审计	按风险自适应但不得超过硬上限
AI 输入无关日志比例	$\leq 10\%$	$\leq 5\%$
Agent 升级回滚成功率	$\geq 95\%$	$\geq 99\%$
不可解释数据丢失	0	0

17.4 数据集治理与可重复评测

- 每个场景数据集包含正常、失败攻击、成功攻击、弱信号、数据缺失、时钟偏差、乱序和重复事件，并记录来源、生成脚本、许可和版本。
- 训练/调优数据与最终验收数据隔离；规则、Prompt 和模型路由不能针对验收集硬编码。
- 评测报告同时给出总体指标和按发行版、Profile、数据源、资产关键度、攻击阶段的分层结果。

- 每次规则、Schema、Collector、模型或 Prompt 变更触发受影响数据集回放，并保存差异、性能和误报变化。
- 攻击仿真只在隔离授权环境执行；真实恶意样本使用安全替代或隔离沙箱，禁止在生产 Agent 直接运行。

18. 分阶段研发计划

本计划不以固定人数或固定周期作为范围约束。各能力可以由多个团队并行推进，但阶段依赖、接口冻结、证据完整性、安全门禁和退出条件不得因资源充足而跳过。MVP 在 P0-P7 后形成；V1.0 在 P12 完成。

18.1 阶段依赖与并行规则

阶段编号表达技术依赖，不表示只能串行开发。并行团队必须通过版本化 Schema、契约测试和集成环境保持可合并；未满足前置退出条件的模块只能进入实验分支，不得进入生产主链路。

阶段	关键前置	可并行工作	硬性门禁
P0	无	威胁模型、Schema、部署剖面、CI/SBOM	接口和信任边界评审通过
P1	P0	API、存储抽象、可观测性、测试框架	迁移、健康、审计和制品链可运行
P2	P0/P1 契约	各发行版 Agent、安装包、缓存和 mTLS	能力探测、签名更新和降级可验证
P3	P1 Schema、P2 批次协议	网关、JetStream、标准化、DLQ	幂等、重放、乱序和非法数据处理通过
P4	P3 标准化事件	网络/Web/SSH 规则和回放集	攻击尝试与成功状态不混淆
P5	P2 Agent、P3 Schema	eBPF/audit/Falco、行为链	L1/L2 降级和跨发行版回归通过
P6	P4/P5 告警	Incident、证据、时间线和图边	判断可跳转原始证据，迟到事件可重算
P7	P6 EvidencePackage	Review Gate、Analyzer、只读工具	模型不可用不影响主链路，Claim 可验证
P8	P7 原子 Claim	Verifier、冲突、注入测试	确定性校验优先，高风险无审核自动降权
P9	P2/P6 文件上下文	静态分析、样本隔离、外部沙箱接口	平台和 Agent 不直接执行样本
P10	P6 实体边	跨主机溯源和导出	不进行无证据身份归因
P11	P6 证据、P8 保证等级	响应、审批、控制台	R2/R3 门禁、目标重验证和回滚通过
P12	全部功能阶段	性能、兼容、安全、试点和发布	最终 Go 标准或正式风险接受

说明：阶段标题不再给出固定周数，项目推进以退出条件和集成门禁为准。

P0 架构与需求冻结

技术任务

- 确认功能域、威胁模型、非目标和验收指标
- 建立 ADR、数据分类、事件 Schema v0.1、API 风格和版本策略
- 选定 MVP 部署剖面及依赖组件
- 建立仓库、CI、代码规范、依赖锁定、SBOM 和安全扫描

交付物

- 架构基线、威胁模型、兼容矩阵、里程碑、测试清单

退出条件

- 关键接口和数据边界评审通过；无未决阻塞性架构问题

P1 Python 核心平台与工程底座

技术任务

- 创建 pyproject.toml、锁文件与 src/blue_team/domain、platform、config 包
- 实现统一错误、配置、日志、指标、OpenAPI、数据库迁移
- 实现 PostgreSQL 基础表和对象存储抽象
- 建立单元、集成、容器测试和制品构建

交付物

- 可启动的 api-server、迁移脚本、CI 制品、基础健康页

退出条件

- 依赖锁定、静态检查、类型检查和全链路测试通过；可创建租户、资产和空事件

P2 通用 Linux Agent 与兼容层

技术任务

- 实现 os-release、init、日志、BTF、LSM、权限能力探测
- 实现 journald/syslog/file tail、进程/资源基础采集
- 实现本地队列、批量、压缩、重试、心跳、mTLS
- 构建 DEB/RPM/tar 安装包、隔离 Python 运行时/虚拟环境和 systemd 单元

交付物

- Agent v0.1、capability report、安装/升级/卸载脚本

退出条件

- Debian/Ubuntu/Kali/Rocky/Fedora/openSUSE 至少各 1 个版本通过基础安装与事件上传

P3 接入网关、消息和标准化

技术任务

- 实现 gRPC EventStream 和证书注册
- 接入 NATS JetStream、ACK、重放、DLQ 和幂等
- 实现事件 Schema 校验、标准化、资产富化
- 实现事件查询和数据新鲜度监控

交付物

- ingest-gateway、normalizer、事件浏览 API

退出条件

- 断网重连无不可解释重复；非法事件进入 DLQ；可重放

P4 网络、Web 与认证检测

技术任务

- Suricata EVE、Nginx/Apache、SSH/PAM/audit 登录适配

- 实现窗口计数、扫描、爆破、敏感路径、异常方法和注入规则
- 实现攻击尝试/阻断/疑似成功的初步状态机
- 构建正常和恶意访问回放集

交付物

- detection-engine v0.1、规则包、Web/SSH 事件

退出条件

- 核心 Web 扫描和 SSH 爆破达到 MVP 指标；正常基线误报可解释

P5 主机运行时与行为链

技术任务

- 实现 BCC Python 绑定或签名后的 libbpf CO-RE 辅助程序进行进程/网络 eBPF 采集，并提供 auditd/Falco 降级
- 采集父子进程、命令、文件、账号、cron/systemd 和网络
- 实现进程-文件-网络序列规则
- 实现 Web 进程启动 shell、下载执行、持久化、横向扫描场景

交付物

- collectors-ebpf/audit/falco、行为链引擎、主机事件页面

退出条件

- 至少三种发行版 L2 能力通过；L1 降级输出明确；成功攻击链可还原

P6 Incident 关联与证据模型

技术任务

- 告警去重、时间窗口聚合、资产/账号/进程实体解析
- 实现原始日志聚合、样本保留、full_query_ref 和 data_reductions 审计
- 实现 evidence、claim、entity、edge 数据结构
- 构建时间线和风险评分
- 支持事件合并、拆分、关闭和反馈

交付物

- incident-engine、证据 API、时间线和关系初版

退出条件

- 同一攻击链能稳定聚合；每个判断可跳转原始证据；万级重复日志可聚合为单 Incident 且保留查询引用

P7 AI Analyzer 与工具网关 (MVP)

技术任务

- 实现 AI Review Gate、ReviewDecision、策略配置和 EvidencePackage
- 实现 ModelProvider、Kimi/GLM/OpenAI-compatible adapter

- 实现结构化 Prompt、JSON Schema、超时/重试/熔断/Token 与成本预算
- 实现只读调查工具和最小权限 Tool Gateway
- 输出原子 Claim、未知项、替代解释和报告

交付物

- ai-review-gateway、ai-orchestrator v0.1、证据包 Schema、模型与预算配置、事件 AI 研判

退出条件

- 模型不可用不影响确定性检测；正常日志不直接触发模型；所有 Claim 有 evidence_id 或明确 unsupported

P8 多模型审核与幻觉验证

技术任务

- 实现 Verifier 槽位、盲审、冲突检测和可选 Adjudicator
- 实现 Claim-Evidence 程序校验、确定性计数/时间/实体验证
- 实现 assurance level、模型历史评分和动态升级
- 实现审核条件、调用次数、上下文、工具次数和速率上限
- 加入 Prompt 注入、恶意日志和全量日志误触发测试

交付物

- evidence-verifier、多模型编排、审核审计页

退出条件

- 不存在引用为 0；高风险无审核时自动降权；注入测试不触发未授权工具

P9 恶意文件与恶意软件识别

技术任务

- YARA-X/ClamAV、hash、MIME/ELF/脚本/归档、信誉接口
- 实现样本安全上传、隔离存储和扫描任务
- 关联文件创建、执行、网络、持久化和多主机传播
- 接入可选沙箱并标准化行为报告

交付物

- malware-engine、样本页面、隔离和扫描 API

退出条件

- 已知样本/安全模拟识别达到目标；单点信号不会直接判定家族

P10 攻击图谱与溯源

技术任务

- 实体规范化、边去重、跨主机和跨事件关联
- 初始入口、横向路径、受影响范围和基础设施聚类
- ATT&CK 技术映射和归因限制模板

- 图谱查询、导出和取证包

交付物

- 关系图、溯源报告、调查导出

退出条件

- 给定测试攻击能还原入口、关键路径和影响范围；不进行无证据身份归因

P11 响应、审批和完整控制台

技术任务

- 实现 nftables/firewalld、进程、文件、账号和取证动作适配器
- 策略门控、审批、目标重验证、回滚和执行后验证
- 完成资产、事件、恶意文件、模型、规则、审批和运营页面
- RBAC、审计、通知和 Webhook

交付物

- response-engine、Web console v1、审计与集成

退出条件

- 关键资产动作必须审批；动作可追溯；至少三类动作可验证回滚

P12 跨发行版硬化、性能与发布

技术任务

- 扩展兼容矩阵和内核版本，完成 DEB/RPM/tar 发布链
- 性能压测、消息积压、存储保留和故障注入
- 安全测试、供应链、升级/回滚、备份恢复
- 试点部署、文档、培训和 Go/No-Go 评审

交付物

- V1.0 制品、兼容报告、性能报告、安全报告、运维手册

退出条件

- 全部最终验收标准达到或有经批准的风险接受

19. 能力组织、风险与资源

19.1 能力域与职责

能力域	核心职责	必须覆盖的专业能力
架构与安全治理	总体架构、信任边界、ADR、跨模块契约、风险接受	分布式系统、安全架构、数据治理、生产评审
Linux Agent 与内核观测	发行版兼容、eBPF/audit、采集、缓存、安装、更新和响应后端	Linux 内核、Python、系统编程、eBPF/libbpf、性能和包管理

能力域	核心职责	必须覆盖的专业能力
数据平台与后端	网关、消息、数据库、证据存储、Incident、API 和多租户基础	Python 后端、异步 I/O、PostgreSQL、流处理、容量和可靠性
检测与威胁研究	规则、行为链、IOC、恶意文件、ATT&CK 映射和评测数据集	蓝队检测、恶意软件、日志分析、攻击复现
AI 研判与验证	Review Gate、Provider、Prompt、工具、Claim 验证、模型评测和成本	LLM 工程、结构化输出、Prompt 注入防护、统计评测
控制台与产品	资产、事件、图谱、时间线、规则、审批、运营和可用性	TypeScript、React/Vue、可视化、交互和权限设计
测试、发布与安全运营	跨发行版、攻击回放、性能、SAST/DAST、供应链、故障和试点	自动化、虚拟化、红蓝对抗、SRE、发布工程

19.2 主要风险

风险	影响	控制措施
eBPF 内核差异	Agent 高级能力不可用或观测缺口	能力探测、BTF/回归矩阵、按 hook 降级、auditd/Falco 替代和支持等级
日志量和成本	存储、延迟和模型费用失控	边缘聚合、分层存储、容量模型、AI Review Gate、证据包和调用预算
AI 集体幻觉	错误研判或处置	确定性验证优先、Claim-Evidence、盲审、冲突升级和人工门控
误处置生产资产	业务中断	响应阶梯、关键度、双人审批、短 TTL、回滚、执行预算和验证
恶意日志注入	模型越权或错误工具调用	数据/指令分离、工具白名单、参数再授权、Schema 和注入评测
样本泄露/执行	感染、外联滥用或合规问题	独立沙箱信任域、无执行存储、默认断网、任务销毁和下载审计
组件过多	研发和运维复杂、故障面扩大	Base/Stream/Analytics/Search/HA 档位，按容量和 SLO 启用
跨发行版测试不足	客户环境失败	Certified/Supported/Experimental 分级、CI/VM 矩阵和明确限制
Agent 供应链被篡改	获得高权限持久化入口	制品/策略签名、SBOM、可复现构建、灰度、吊销和防降级
模型数据出域	敏感信息泄露或合规违规	数据分级、字段白名单、本地模型、租户策略、短期保留和调用审计
事件乱序与重复	时间线错误、重复告警或重复响应	boot_id/sequence、watermark、幂等键、版本化结论和重放测试
Schema 与规则漂移	历史事件无法解释或升级中断	版本化 Schema、向后兼容、迁移、历史回放和契约测试

20. 最终验收标准

类别	Go 标准
兼容性	覆盖目标发行版代表版本；基础模式全部通过，完整能力按 Profile 和支持等级标注，安装成功不得替代能力验证。
检测	网络/Web/认证/主机/恶意文件核心场景达到第 17 章指标，攻击尝试、疑似成功和确认失陷能够区分。
证据	所有确认失陷结论具备可访问 evidence_id；不存在引用、跨租户引用和伪造查询结果为 0。
事件质量	断网、重放、迟到、时钟偏差和重复事件处理通过；不存在不可解释数据丢失或重复响应。
AI 门控	原始日志不直接调用模型；仅通过 AI Review Gate 的 Incident 创建 AIReviewTask；聚合、采样、预算和降级可审计。

类别	Go 标准
AI	至少两种 Provider 和本地/不可用降级流程可运行；确定性工具结果优先于模型，多模型一致不作为事实证明。
幻觉与注入	逐 Claim 验证、盲审、冲突升级、Prompt 注入和恶意工具参数测试通过；未授权工具调用为 0。
数据出域	数据分级、租户策略、字段最小化、外部 Provider 限制和模型输入输出保留策略通过审计。
溯源	能还原入口、主机内行为、横向路径和影响范围；归因限制明确，迟到证据可触发版本化修订。
恶意软件	YARA-X/ClamAV/上下文关联可用，样本存储隔离；动态沙箱如启用则独立信任域并通过逃逸和外联测试。
响应	R0-R3 响应阶梯、审批、审计、目标重验证、执行预算和回滚可用；关键资产无未审批 R3 动作。
供应链	Agent、服务、策略、规则和插件制品签名，SBOM、漏洞扫描、灰度升级、防降级和证书吊销完整。
工程	升级回滚、备份恢复、容量告警、故障演练、监控和运维手册完整；可选组件故障不阻断基础检测。
性能	Agent 各 Profile 资源、中心吞吐、积压恢复、检索和 API 满足容量报告；压测可重复。
Go/No-Go	真实攻击回放不稳定、正常日志大规模触发 AI、确认失陷存在无证据 Claim、样本越界执行或高风险动作不可控时，不得进入生产。

Go/No-Go 原则：如果真实攻击回放无法稳定复现、正常日志仍会大规模触发模型、确认失陷结论仍存在无证据 Claim、或者响应动作无法受控回滚，则不得进入生产试点。

附录 A. Python 工程目录建议

```

project/
├── pyproject.toml          # 项目、构建、工具和依赖声明
├── uv.lock                 # 锁定依赖与可重复安装
├── src/
│   ├── blue_team/
│   │   ├── domain/        # 统一领域模型与 Pydantic Schema
│   │   ├── platform/      # Linux 发行版/内核适配
│   │   ├── agent_core/
│   │   ├── collectors/
│   │   │   ├── journald.py
│   │   │   ├── audit.py
│   │   │   ├── suricata.py
│   │   │   ├── falco.py
│   │   │   ├── ebpf.py
│   │   │   └── file.py
│   │   ├── ingest_gateway/
│   │   ├── normalizer/
│   │   ├── detection_engine/
│   │   ├── malware_engine/
│   │   ├── incident_engine/
│   │   ├── ai_review_gateway/
│   │   ├── evidence_verifier/
│   │   ├── ai_orchestrator/
│   │   ├── response_engine/
│   │   ├── storage/
│   │   └── api_server/
│   ├── ebpf/
│   │   ├── probes/        # 受限 C/libbpf CO-RE 探针或预编译对象
│   │   └── loaders/       # BCC/libbpf Python 加载与事件适配
│   ├── proto/            # gRPC/Protobuf 契约
│   ├── web/              # TypeScript 控制台
│   ├── rules/            # network/host/file/sequence
│   ├── schemas/          # json-schema/openapi
│   ├── deploy/           # deb/rpm/systemd/container/helm
│   ├── tests/            # unit/integration/replay/attack/compat/performance
│   ├── scripts/          # 构建、签名、离线包和维护脚本
│   └── docs/             # ADR/运维/接口/威胁模型

```

附录 B. Claim 与审核 Schema

```
{
  "incident_id": "inc_01...",
  "assurance_level": "enhanced",
  "claims": [{
    "claim_id": "clm_01...",
    "category": "malware_execution",
    "statement": "host-01 执行了高度疑似挖矿程序",
    "epistemic_status": "inferred",
    "evidence_ids": ["evt_1", "evt_2", "file_1"],
    "support_score": 0.86,
    "contradiction_score": 0.05,
    "review_status": "partially_verified",
    "unknowns": ["尚未确认恶意软件家族"],
    "alternative_explanations": ["合法性能测试程序"]
  }],
  "allowed_response": "recommend_only"
}
```

附录 C. Agent 事件批次接口示例

```
message EventBatch {
  string agent_id = 1;
  string tenant_id = 2;
  string batch_id = 3;
  uint64 sequence_start = 4;
  uint64 sequence_end = 5;
  repeated SecurityEvent events = 6;
  bytes integrity_digest = 7;
}

message BatchAck {
  string batch_id = 1;
  uint64 accepted_sequence = 2;
  repeated EventError errors = 3;
  optional AgentPolicy policy_update = 4;
}
```

附录 D. AI Review Gate 配置与接口示例

```
from typing import Protocol
from pydantic import BaseModel, Field

class AiReviewGate(Protocol):
    async def evaluate(
        self,
        incident: Incident,
        context: IncidentContext,
    ) -> ReviewDecision: ...

class EvidencePackage(BaseModel):
    review_task_id: str
    incident_id: str
    reason: str
    risk_score: int = Field(ge=0, le=100)
    aggregate_metrics: dict[str, object]
    evidence_ids: list[str]
    sample_event_ids: list[str]
    full_query_ref: str | None = None
    available_tools: list[str]
```

控制项	默认建议	目的
minimum_severity	medium	低风险事件不进入模型
max_raw_log_samples	20	限制原始日志样本
max_context_tokens	16000	限制上下文冗余与费用
max_tool_calls	8	防止无限调查循环
max_model_runs_per_incident	3	限制 Analyzer/Verifier/Adjudicator 总次数
max_reviews_per_minute	30	Provider 速率和成本保护
critical_asset_always_review	true	关键资产提高保证等级

附录 E. 容量规划与压测模板

容量报告必须使用代表业务数据和峰值模型，至少填写下表参数，并保留压测脚本、配置、原始结果和分析结论。

参数	示例/单位	来源与说明
平均/峰值 EPS	events/s	按数据源、Profile、租户和资产组分层
事件大小分布	P50/P95/P99 bytes	区分原始、标准化和索引后大小
压缩比	x:1	按 Protobuf/zstd、JSON、对象存储分别测量
保留周期	天	热/温/冷和法规要求
消息故障窗口	分钟/小时	中心不可用、网络中断和升级窗口
复制与预留	factor / %	HA 副本、对象版本和至少 30% headroom
查询负载	QPS、时间窗、并发	事件详情、聚合、全文和图查询分别测量
恢复目标	RPO/RTO	数据库、对象存储、消息和 Agent 队列分别定义

压测必须覆盖稳定负载、突发峰值、消息积压、磁盘接近满、依赖超时、重放、租户热点和模型 Provider 不可用。测试结论应明确当前部署档位的最大安全容量和扩容触发点。

附录 F. 威胁模型与信任边界检查清单

边界/资产	主要威胁	强制控制
Agent root/高权限进程	本地提权、配置篡改、身份复制、恶意升级	最小 capability、签名制品、证书绑定、灰度和完整性事件
Agent 到中心链路	伪造 Agent、重放、流量篡改、租户混淆	mTLS、一次性注册、序列/批次完整性、租户绑定和吊销
接入与消息总线	事件洪泛、Schema 绕过、跨租户消费	大小/速率限制、Schema、ACL、分区隔离、DLQ 和背压
证据存储	未授权读取、覆盖、样本执行、生命周期失控	不可变引用、完整性哈希、不可执行挂载、加密和短期授权
AI 与工具网关	Prompt 注入、越权查询、任意工具参数、数据出域	数据/指令分离、工具白名单、参数再授权、数据分级和预算
插件与沙箱	供应链植入、逃逸、外联滥用、结果伪造	签名清单、WASM capability、独立网络、任务销毁和结果校验
响应执行器	误操作、目标替换、PID 复用、批量破坏	固定动作、目标重验证、审批、执行预算、回滚和验证
控制台与 API	越权、CSRF/会话滥用、审计绕过	RBAC/ABAC、强认证、CSRF 防护、操作审计和敏感字段最小化

附录 G. 首个可验证闭环基线

该基线不是因资源不足而缩减的最终产品，而是用于证明数据真实性、检测有效性、AI 边界和响应可控性的强制集成门槛。达到该门槛后，其他能力可以继续并行扩展。

域	基线能力	通过标准
兼容	Ubuntu/Debian 与 Rocky 代表版本；其他发行版可并行进入 Supported/Experimental	安装、升级、卸载、能力探测、L1/L2 降级和断网恢复通过
采集	journald、auditd、Web/SSH、Suricata、进程执行、出站连接、文件 hash	事件具有 host/boot/sequence/time/raw_ref，丢弃和采样可审计
检测	扫描、爆破、攻击尝试、Web 进程 shell、下载执行、异常外联、基础持久化	攻击尝试与成功分层；规则回放达到验证指标
关联与证据	Incident、时间线、实体、evidence_id、full_query_ref、迟到修订	每个严重结论可跳转原始证据，重复/乱序不产生重复响应
AI	Review Gate、单 Analyzer、确定性 Claim 校验、只读工具、Provider 降级	模型不可用不影响主链路；不存在证据引用为 0
恶意文件	SHA256、YARA-X、ClamAV、ELF/脚本元数据和执行上下文	不依赖单点信号，不在 Agent/中心直接执行样本
响应	建议、取证、审批、短时 IP 封禁与回滚	Action Runner 不接收任意 shell；目标重验证和执行后验证通过
运营	资产、Incident、时间线、证据、Claim、模型和动作审计页面	分析员能够完成一次攻击调查、审核和处置闭环

参考资料

- **Suricata EVE JSON Output:** <https://docs.suricata.io/en/latest/output/eve/eve-json-output.html>
- **Suricata EVE JSON Format:** <https://docs.suricata.io/en/latest/output/eve/eve-json-format.html>

- **Falco Outputs and Output Channels:** <https://falco.org/docs/concepts/outputs/>
- **YARA-X 官方文档:** <https://virustotal.github.io/yara-x/>
- **Python 官方文档:** <https://docs.python.org/3/>
- **FastAPI 官方文档:** <https://fastapi.tiangolo.com/>
- **gRPC Python AsyncIO API:** https://grpc.github.io/grpc/python/grpc_asyncio.html
- **SQLAlchemy AsyncIO:** <https://docs.sqlalchemy.org/en/20/orm/extensions/asyncio.html>
- **BCC Python 开发者教程:**
https://github.com/iovisor/bcc/blob/master/docs/tutorial_bcc_python_developer.md
- **NATS JetStream Concepts:** <https://docs.nats.io/concepts/jetstream>
- **Kimi Tool Calls / JSON Mode:** <https://platform.moonshot.cn/docs/guide/use-kimi-api-to-complete-tool-calls>
- **Kimi Chat Completions API:** <https://platform.moonshot.cn/docs/api/chat>
- **智谱 GLM OpenAI API 兼容与 Function Calling:**
<https://docs.bigmodel.cn/cn/guide/develop/openai/introduction>